

CPF Gateway 개발/사용 가이드

Gateway 선택 여부부터 Route·Security·Retry·Canary·운영 경계를 설명합니다.

문서 기준

Documentation Harness v2.1.0

기준 Source

master 054d894b47f4be8323439dc6f9e58b7d8b60fe54

기준일

2026-08-26

이 문서는 최신 Source 의 공개 계약과 운영 경계를 기준으로 작성하며, 실행하지 않은 검증을 성공으로 기록하지 않습니다.

목차

역할과 질문을 기준으로 필요한 절을 빠르게 찾습니다.

1. Gateway 사용 여부와 Topology

- 1.1 사용/미사용 선택 기준
- 1.2 Gateway 가 담당하는 경계
- 1.3 Gateway 없이 배포하는 경우

2. Routing 과 Domain Route

- 2.1 Route 규칙
- 2.2 Domain Route
- 2.3 Discovery/Target
- 2.4 잘못된 Route

3. Context 와 Security

- 3.1 System6/Context
- 3.2 Authentication
- 3.3 Authorization
- 3.4 Trust Boundary

4. Timeout · Retry · Rate Limit

- 4.1 Timeout/Deadline
- 4.2 Retry 조건

- 4.3 Rate Limit

- 4.4 Circuit/Failure

5. HTTP Error Mapping

- 5.1 401 · 403 · 404 · 409

- 5.2 429

- 5.3 500 · 503

- 5.4 Client/운영 조치

6. HA · Canary · Rollback

- 6.1 HA

- 6.2 Canary

- 6.3 Rollback

- 6.4 Gateway 장애 시 영향

7. 개발 · 운영 · Source

- 7.1 최소 개발 예

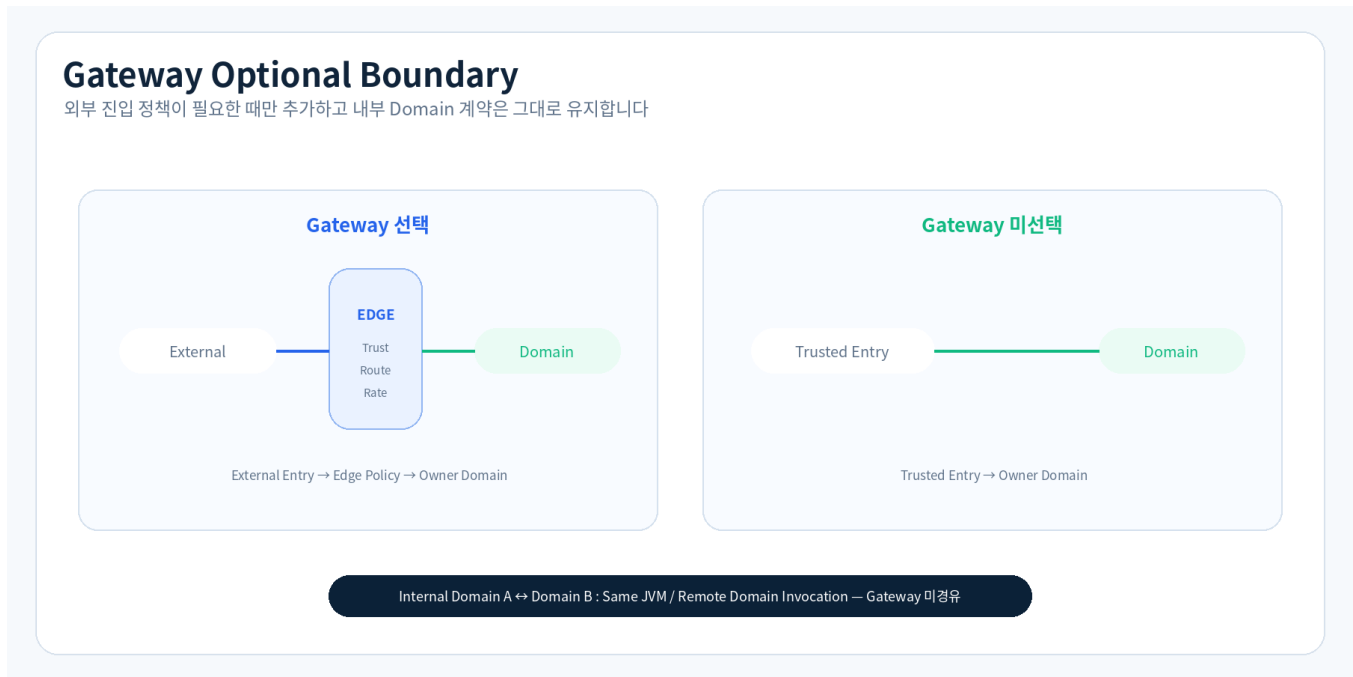
- 7.2 Health/운영 확인

- 7.3 금지 우회

- 7.4 Source/API 길찾기

1. Gateway 사용 여부와 Topology

그림 1-1. Gateway Optional Boundary



Gateway 는 외부 Entry Policy 가 필요할 때만 선택하며 내부 Domain 호출 경계는 그대로 유지합니다.

1.1 사용/미사용 선택 기준

Gateway 는 외부 진입, trust normalization, routing, rate/resilience 가 필요한 경우 선택합니다. 내부 Same JVM 호출이나 Gateway 가 필요 없는 배포는 공식 Domain Invocation 계약을 그대로 사용합니다.

- 선택하지 않은 Optional 기능의 숨은 Side Effect 가 없어야 합니다.
- Source identifier 와 실행 Evidence 를 기준으로 완료 여부를 판단합니다.

1.2 Gateway 가 담당하는 경계

Gateway 는 외부 진입·trust normalization·routing·rate/resilience 를 담당하는 Optional Edge 입니다. 업무 로직과 Business DB 는 Gateway 에 두지 않습니다.

- Gateway 없이 배포하는 topology 도 공식 Domain 계약을 유지합니다.
- Route 변경은 health/drainning/canary/rollback 과 함께 운영합니다.

1.3 Gateway 없이 배포하는 경우

Gateway 를 사용하지 않는 배포에서도 업무 Domain 은 동일한 Domain Invocation 과 System6 계약을 유지합니다. Gateway 제거가 업무 코드나 Owner DB 경계를 바꾸는 조건이 되어서는 안 됩니다.

상황에 맞는 선택과 피해야 할 경로를 판단합니다.

배포 방식이 달라도 유지해야 할 호출 계약을 비교합니다.

표 1-1. 관점 / Same JVM / Remote / 공통 계약

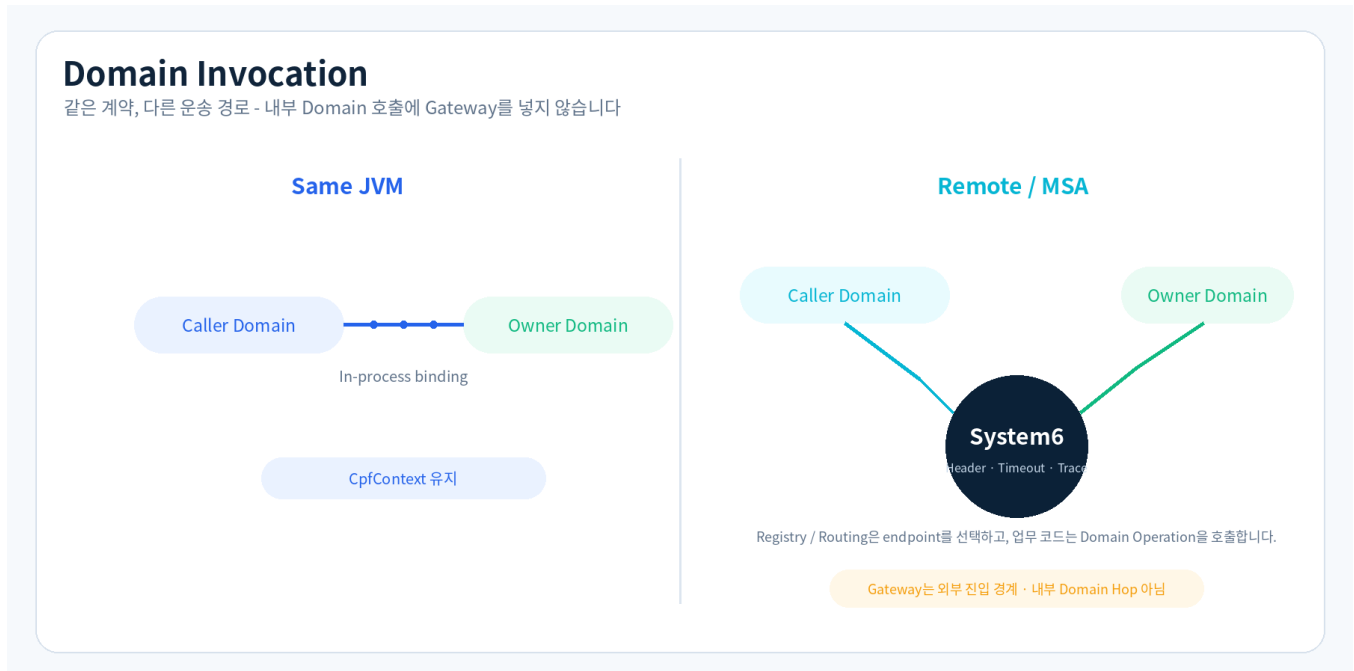
비교·선택·확인에 필요한 항목만 압축해 정리합니다.

관점	Same JVM	Remote	공통 계약
호출 경로	In-process route	Registry+transport	Domain Invocation
Context	CpfContext	System6 serialize	동일 논리 Context
실패	직접 예외/Result	timeout·network	표준 Error/UNKNOWN
관측	동일 trace	hop trace	transaction/operation 유지

Source 길찾기 [cpf-gateway/src/main/java/com/cpf/gateway/api/CpfGatewayRoute.java](#)

2. Routing 과 Domain Route

그림 2-1. Routing 과 Domain Invocation



Route 가 endpoint 를 고르더라도 업무 코드는 Domain Operation 을 호출하며 내부 Hop 을 Gateway 로 우회하지 않습니다.

2.1 Route 규칙

Route 는 System·Target·Operation 식별과 discovery 결과를 기준으로 Owner Domain 에 연결합니다. Route 변경은 health, draining, canary, rollback 절차와 함께 관리합니다.

2.2 Domain Route

Domain Route 는 Gateway 내부 업무 구현이 아니라 Owner Domain 으로 전달할 대상 결정을 표현합니다. Gateway 가 Business DB 를 직접 조회해 route 를 결정하지 않습니다.

2.3 Discovery/Target

Discovery 는 실행 가능한 Target instance 를 찾는 runtime 정보이고 Route 는 어느 Owner Domain 으로 보낼지 결정하는 계약입니다. 둘을 Operation 정의의 생성·삭제와 혼동하지 않습니다.

Discovery 결과는 현재 실행 가능한 Target 을 고르는 근거로 사용하며, 일시적인 미발견을 Operation 정의의 자동 삭제 사유로 사용하지 않습니다.

2.4 잘못된 Route

Target·Operation 이 실제 Handler 와 일치하지 않거나 실행 가능한 대상이 없으면 업무 Controller 실행 전에 실패로 종료하고 오류를 trace 와 운영 상태에 연결합니다.

작업에 사용할 Public API 와 실패 주의점을 확인합니다.

기본값이 아닌 실제 선택이 필요한 옵션을 확인합니다.

Source 길찾기 [cpf-gateway/src/main/java/com/cpf/gateway/api/CpfGatewayRoute.java](https://github.com/CPF/CPF-Source/blob/master/cpf-gateway/src/main/java/com/cpf/gateway/api/CpfGatewayRoute.java)

3. Context 와 Security

3.1 System6/Context

업무 Online Transaction 은 Controller 실행 전에 Canonical System6 를 갖습니다. Transaction/Original 은 유지하고 System/Caller/Target/Operation 은 Hop 기준으로 CPF 가 확정합니다.

- Browser 가 Protected Header 를 보내도 신뢰하지 않고 Trusted Entry 에서 재구성합니다.
- 수신 System/Target/Operation 이 실제 Runtime/Handler 와 다르면 업무 Controller 를 호출하지 않습니다.

3.2 Authentication

Security 는 Authentication 이후 Authorization/Permission 을 분리해 평가하고 Session/Token lifecycle 을 Runtime 경계에 맞춥니다. 관리 기능과 업무 기능은 서로 다른 권한 Surface 를 가집니다.

- Protected Header 와 사용자 credential 을 동일 identity 로 취급하지 않습니다.
- 401/403 은 원인을 구분하고 실패도 audit/trace 와 연결합니다.

3.3 Authorization

Authorization 은 인증된 identity 가 현재 Route/Operation 을 호출할 권한이 있는지 평가합니다. Route 존재 여부와 권한 부족을 같은 404/403 의미로 섞지 않습니다.

- Route 정책과 Owner Domain 의 업무 권한을 각각 검사하되 Gateway 가 업무 권한 원장을 직접 소유하지 않습니다.
- 401/403 은 원인을 구분하고 실패도 audit/trace 와 연결합니다.

3.4 Trust Boundary

Trust Boundary 에서는 Browser·외부 Client 가 보낸 Protected Header 를 신뢰하지 않고 Trusted Entry 에서 System6 와 사용자 identity 를 재구성·검증합니다.

Protected Header 는 외부 입력을 그대로 신뢰하지 않고 Trusted Entry 에서 재구성·검증한 뒤 내부 Context 로 전달합니다.

각 Header 의 설정 주체·변경 규칙·수신 검증을 확인합니다.

표 3-1. Header / 설정 주체 / 변경 규칙 / 검증/주의

비교·선택·확인에 필요한 항목만 압축해 정리합니다.

Header	설정 주체	변경 규칙	검증/주의
X-Transaction-Id	CPF	최초 생성 후 불변	거래 전체 correlation
X-Original-System-Code	CPF Trusted Entry	최초 확정 후 불변	호출자가 임의 변경 금지
X-System-Code	CPF	Hop 마다 현재 처리 System	수신 Runtime 과 일치
X-Caller-System-Code	CPF	Hop 마다 직전 Caller	신뢰 System identity 사용
X-Target-System-Code	CPF	Hop 마다 Target	수신 Runtime 과 일치
X-Target-Operation-Id	CPF	Operation 마다 갱신	실제 Handler 와 일치

작업에 사용할 Public API 와 실패 주의점을 확인합니다.

Source [찾기](#) `cpf-gateway/src/main/java/com/cpf/gateway/runtime/CpfApiClientSecurityPolicy.java`

4. Timeout·Retry·Rate Limit

4.1 Timeout/Deadline

Timeout/Deadline 은 Caller 의 남은 시간과 Target/Provider 제한을 함께 고려해 전파합니다. 하위 hop 에서 임의로 더 긴 timeout 을 만들어 상위 deadline 을 넘기지 않습니다.

Timeout 은 hop 마다 독립적으로 늘리지 않고 남은 deadline 과 대상 Provider 한계를 함께 고려해 전달합니다.

4.2 Retry 조건

Retry 는 일시 실패하면서 멍등성 또는 재실행 안전성이 확보된 경우에만 허용합니다. 원격 결과가 UNKNOWN 이면 먼저 Reconcile 합니다.

Retry 는 멍등성 또는 재실행 안전성이 확보되고 결과가 UNKNOWN 으로 남아 있지 않은 조건에서만 수행합니다.

4.3 Rate Limit

Rate Limit 은 호출자·Target·정책 단위로 과부하를 제한하고 429 응답에 backoff/Retry-After 를 적용해 retry storm 을 방지합니다.

Rate Limit 은 호출자와 대상 정책 단위로 적용하고 429 응답이 retry storm 으로 증폭되지 않도록 backoff 와 재시도 상한을 함께 둡니다.

4.4 Circuit/Failure

Circuit 은 반복되는 Target 실패를 일정 기간 차단해 장애 확산을 줄이고, 상태 전환과 half-open Probe 결과를 운영 Trace 에 연결합니다.

- Circuit open 상태에서는 무조건 downstream 을 재호출하지 않고 정해진 Probe/복구 조건을 따릅니다.
 - timeout·retry·circuit 조합이 retry storm 이나 예상보다 긴 총 deadline 을 만들지 않는지 검증합니다.
- 기본값이 아닌 실제 선택이 필요한 옵션을 확인합니다.

오류 상태에서 Retry·복구·확인 순서를 판단합니다.

Source [길찾기](#) `cpf-gateway/src/main/java/com/cpf/gateway/internal/resilience/CpfGatewayResilientInvoker.java`

5. HTTP Error Mapping

5.1 401·403·404·409

401·403·404·409 는 서로 다른 원인을 표현합니다. 인증, 권한, 대상 부재, 상태 충돌을 동일 오류로 매핑하지 않고 Client 와 운영 조치를 구분합니다.

401/403 은 인증·권한 실패, 404 는 route/target 부재, 409 는 상태 충돌로 구분해 Client 와 운영 조치를 다르게 합니다.

5.2 429

429 는 용량 또는 정책 한계에 따른 거절입니다. 즉시 반복 호출보다 Retry-After, backoff 와 호출량 제어를 적용합니다.

429 는 처리 용량 또는 정책 한계에 따른 거절로 다루며 Retry-After·backoff 정책 없이 즉시 반복 호출하지 않습니다.

5.3 500·503

500 은 처리 실패, 503 은 일시 가용성 저하로 구분합니다. 503 은 health/discovery 상태를 확인하고 제한된 재시도를 적용합니다.

500 은 처리 실패, 503 은 일시적 가용성 저하로 구분하고 503 재시도 전 health 와 target 상태를 확인합니다.

5.4 Client/운영 조치

Client 는 오류별 재시도 가능 여부를 따르고 운영자는 transactionId·operationId·instanceId 로 Route 와 Target 상태를 추적합니다.

Client 는 HTTP 상태별 재시도 가능 여부를 구분하고, 운영자는 transactionId·operationId·instanceId 로 실패 경로와 target 상태를 확인합니다.

HTTP 상태별 원인 확인과 운영 조치를 구분합니다.

표 5-1. HTTP / 의미 / 우선 확인 / 조치

비교·선택·확인에 필요한 항목만 압축해 정리합니다.

HTTP	의미	우선 확인	조치
401	인증 실패	credential/session	재인증
403	권한 실패	permission/policy	권한/승인 확인
404	대상/route 없음	operation/route	등록·경로 확인
409	상태 충돌	version/idempotency	현재 상태 재조회
429	Rate 제한	quota/window	backoff

HTTP	의미	우선 확인	조치
500	내부 오류	trace/errorCode	원인 분석
503	가용성 오류	health/draining	우회·복구 후 재시도

Source [길찾기 cpf-gateway/src/main/java/com/cpf/gateway/runtime/CpfGatewayRuntimePolicy.java](#)

6. HA·Canary·Rollback

6.1 HA

Multi-instance 에서는 Process-local 상태를 정답으로 사용하지 않습니다. Registry, durable state, cache invalidation, lease/fencing 으로 인스턴스 간 일관성과 장애 격리를 확보합니다.

- 한 Instance 장애가 전체 System 상태로 오관되지 않게 health 를 instance/system 축으로 봅니다.
- mixed deployment 중 discovery 차이를 즉시 삭제 사유로 사용하지 않습니다.

6.2 Canary

Canary 는 일부 Route/instance 에 신규 버전을 제한 적용하고 latency·error·health 를 비교합니다. 이상 시 기존 Route 로 즉시 되돌릴 수 있어야 합니다.

Canary 는 일부 인스턴스나 route 에 제한 적용한 뒤 error/latency/health 를 확인하고 이상 시 즉시 기존 route 로 되돌릴 수 있어야 합니다.

6.3 Rollback

Gateway Rollback 은 신규 Route/Policy/Target 버전의 이상을 확인했을 때 직전 정상 버전으로 되돌리는 조치입니다. Business Domain 데이터나 원격 Side Effect 를 되돌리는 의미와는 분리합니다.

- Rollback 전 현재 publish version, canary 대상, draining 상태와 LKG(Last Known Good)를 확인합니다.
- Rollback 후 health·route resolution·오류율이 이전 정상 기준으로 돌아왔는지 확인합니다.

6.4 Gateway 장애 시 영향

Gateway 장애는 외부 진입 경로의 가용성 문제이며 Owner Domain 의 내부 계약과 데이터 소유권을 변경하지 않습니다. HA 와 health/draining 으로 인스턴스 단위 영향을 격리합니다.

상황에 맞는 선택과 피해야 할 경로를 판단합니다.

운영 상황별 확인·조치·완료 기준을 확인합니다.

Source [길찾기 cpf-gateway/src/main/java/com/cpf/gateway/api/CpfGatewayRoute.java](#)

7. 개발·운영·Source

7.1 최소 개발 예

최소 Gateway 연계를 Route, System6 전달, timeout/error mapping, health 확인까지 포함하고 업무 로직과 Business DB 접근은 Owner Domain 에 둡니다.

최소 Gateway 연계를 route 정의, System6 전달, timeout/error mapping, health 확인까지 포함하고 업무 로직은 Owner Domain 에 둡니다.

// 업무 코드는 Gateway endpoint 가 아니라 Domain/Operation 계약을 호출합니다.

```
CpfDomainClient client = ...;
```

```
client.call(/* target domain + operation */);
```

7.2 Health/운영 확인

Observability 는 transactionId·operationId·instanceId 를 중심으로 Log, Trace, Metric, Timeline 을 연결합니다. 운영자는 코드 위치보다 거래·실행 식별자에서 시작해 원인을 좁힐 수 있어야 합니다.

- 민감정보는 structured log 에서도 마스킹합니다.
- 재시도/복구 segment 가 원 거래와 단절되지 않도록 correlation 을 유지합니다.

7.3 금지 우회

금지 패턴은 Owner·Topology·신뢰 경계를 우회하거나 운영 Evidence 를 잃게 만드는 구현을 빠르게 차단하기 위한 Review Gate 입니다.

- self-HTTP, 타 Owner DB/Internal 직접 참조, secret 원문 로그를 금지합니다.
- 미실행 검증·stale Evidence·Optional 기능의 숨은 Side Effect 를 완료 근거로 사용하지 않습니다.

7.4 Source/API 길찾기

Gateway Source 를 찾을 때는 routing, security, resilience, discovery, operations Public Surface 와 실제 Consumer Route 를 함께 확인합니다.

정상·실패·복구까지 통과해야 할 시나리오를 확인합니다.

계약과 실제 Consumer 를 확인할 Source 위치를 찾습니다.

Source 길찾기 [cpf-gateway/src/main/java/com/cpf/gateway/api/CpfGatewayRoute.java](#)